SharePoint Online External Sharing & Access Governance

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — SharePoint Online External Sharing & Access Governance 4

1. Solution Overview — SharePoint Online External Sharing & Access Governance 4

What this solution is . . . 4

Scope — what this is, and what it deliberately is NOT . . . 5

The determination boundary (read this before configuring) . . . 5

Why this matters . . . 5

How it works . . . 6

The reference model (artifacts this solution creates) . . . 7

Benefits . . . 7

Limitations (be honest with buyers) . . . 8

The standard deployment model . . . 8

2. Requirements — SharePoint Online External Sharing & Access Governance 9

2.1 SharePoint Administrator role (and Global Admin only where noted) . . . 9

2.2 SharePoint Online Management Shell connected to the admin endpoint . . . 9

2.3 PnP PowerShell for link + permission enumeration . . . 10

2.4 Microsoft Graph PowerShell for guests and access reviews . . . 10

2.5 A documented external-sharing policy (from the policy owner) . . . 10

2.6 Sensitivity labels published (if label-driven controls are in scope) . . . 11

2.7 Entra ID Governance licensing for Access Reviews (if reviews are in scope) . . . 11

2.8 A named pilot scope of sites and users . . . 12

Global Requirements — SharePoint Online & OneDrive Solutions 12

1. Microsoft 365 tenant with SharePoint Online / OneDrive and licensing . . . 12

2. Administrative access (least-privilege SharePoint roles) . . . 13

3. SharePoint Online Management Shell / PnP + Graph toolchain . . . 13

4. Information architecture & identity/group source of truth . . . 13

5. A pilot scope and change control . . . 13

6. Security, compliance & records stakeholders . . . 14

3. Implementation — SharePoint Online External Sharing & Access Governance 14

Stage 0 — Assess (read-only, changes nothing) . . . 14

Stage 1 — Design (with the policy owner; no changes yet) . . . 15

Stage 2 — Configure & Pilot . . . 16

Stage 3 — Validate . . . 17

Stage 4 — Expand . . . 18

Rollback summary (keep ready at every stage) . . . 18

5. Testing & Validation — SharePoint Online External Sharing & Access Governance 18

T1 — Tenant sharing baseline is in effect . . . 19
T2 — OneDrive sharing is no looser than the tenant . . . 19
T3 — Default sharing link is Specific people / View . . . 19
T4 — Anyone-link expiration is enforced (only if Anyone is permitted) . . . 19
T5 — External sharing level blocks disallowed link types . . . 20
T6 — Guest-access expiration applies to new guests . . . 20
T7 — Domain allow/block restriction is enforced . . . 20
T8 — Sensitivity-label container control is applied (if in scope) . . . 20
T9 — External-exposure report is complete and accurate . . . 21
T10 — Guest access review runs and removes stale access . . . 21
T11 — Rollback works . . . 21
6. Troubleshooting — SharePoint Online External Sharing & Access Governance 22
Connection & tooling . . . 22
Settings not taking effect . . . 22
Sharing behavior surprises . . . 23
Sensitivity labels . . . 24
Reporting & reviews . . . 24
Government cloud . . . 24
7. Best Practices — SharePoint Online External Sharing & Access Governance 25
Policy first, settings second . . . 25
Safe defaults beat after-the-fact cleanup . . . 25
Tighten by tier, not tenant-wide only . . . 25
Domains: allow-list when you can . . . 25
Guests are a lifecycle, not a one-time invite . . . 26
Make exposure visible on a cadence . . . 26
Operate safely . . . 26
8. Deliverables Summary — SharePoint Online External Sharing & Access Governance 27
Documentation . . . 27
PowerShell scripts (5) . . . 27
The named artifacts you end up with . . . 29
Appendix A — PowerShell Scripts 30

Executive Summary — SharePoint Online External Sharing & Access Governance

The outcome. External sharing in SharePoint Online and OneDrive stays **enabled where the business needs it, but becomes scoped, defaulted safely, time-boxed, domain-restricted, reviewed, and auditable.** The organization moves from an unmeasured posture — where links can default to "Anyone", never expire, reach any domain, and pile up invisibly — to a **governed** one where sharing is controlled and external exposure is visible on a cadence.

The approach. The engagement sets the **tenant sharing level** to the least-open value that still lets people collaborate, aligns **OneDrive** to match, and makes **sensitive sites tighter** than the tenant default. New links **default to Specific people / View**, **Anyone-links and guest access expire**, and sharing is **restricted to approved partner domains** (allow-list) or blocked domains. Where the compliance team has published **sensitivity labels**, their container controls carry the sharing posture as a unit. **Guest access is reviewed on a recurring cadence**, and a recurring **external-exposure report** turns the historic blind spot into a monitored signal. Five PowerShell tools (SharePoint Online Management Shell / PnP / Microsoft Graph) do the discovery, configuration, validation, and reporting.

Why it is low-risk. Tenant-wide sharing is a high-impact change, so the work follows a disciplined **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand** model. Nothing is changed without an **approved policy** from the security/compliance owner. Every configuration script is **safe by default** — read-only or dry-run until an explicit `-Commit` — and stores **no credentials**. Changes are proven on a **named pilot** first, applied tenant-wide only in a **change window with a staged rollback**, and gated by **explicit pass/fail checks** before any expansion. The policy determination stays with its owners (security, compliance, records); this solution supplies the technical method, the evidence, and the reporting — not the decision.

What the buyer gets. A complete, self-guided implementation: overview, requirements, step-by-step implementation, an 11-test validation suite, troubleshooting, best practices, and five production-grade PowerShell scripts — the same work a consulting engagement would deliver, at a fraction of the cost, and repeatable in-house.

1. Solution Overview — SharePoint Online External Sharing & Access Governance

What this solution is

External sharing is the feature that lets SharePoint Online and OneDrive for Business drive collaboration with partners, vendors, and customers — and it is also the single largest lever for accidental data exposure. This solution **governs external sharing and access** end to end: it sets the **tenant-level sharing capability**, aligns **OneDrive** sharing to policy, tunes **site-level sharing** so sensitive sites are tighter than the tenant default, sets **sharing-link defaults and expiration** (so links stop defaulting to "Anyone" and stop living forever), enforces **allow/block domain** restrictions, wires **sensitivity-label-driven** controls on site containers, stands up **guest access reviews**, and produces **external-exposure reporting** so the organization can see who outside the company can reach what.

The work is done in the **SharePoint admin center** and **Microsoft 365 admin center**, the **Microsoft Entra admin center** (guests and access reviews), and the **Microsoft Purview portal** (sensitivity labels), and automated with **SharePoint Online Management Shell** (`Set-SPOTenant` / `Set-SPOSite`), **PnP PowerShell**, and **Microsoft Graph**. The result: sharing stays **enabled** where the business needs it, but it is **scoped, defaulted safely, time-boxed, domain-restricted, reviewed, and auditable**.

Scope — what this is, and what it deliberately is NOT

This solution is **scoped to external sharing and external access governance** for SharePoint Online and OneDrive: the tenant/OneDrive/site sharing capability, sharing-link types + defaults + expiration, external-domain allow/block, applying (not designing) sensitivity labels that carry container sharing controls, guest lifecycle + access reviews, and external-exposure reporting.

It is **not**:

- **Internal permissions management.** Site groups, permission levels, "broken" inheritance, and

Everyone/Everyone-Except-External-Users (EEEU) cleanup are **internal** access and are a **separate product** (SharePoint permissions & access management). This solution touches internal permissions only where they create *external* exposure (an EEEU claim, an anyone-link).

- **Records, retention, or DLP.** Retention labels, records disposition, and Data Loss Prevention are a

separate Microsoft Purview product. This solution *applies* a sensitivity label's **container** (site/group) sharing controls; it does **not** design the label taxonomy or its file-level encryption/DLP — **that is the compliance/records owner's determination** (see below).

- **Conditional Access / device policy.** Unmanaged-device restrictions (`-ConditionalAccessPolicy`,

App-Enforced Restrictions) are referenced where they intersect sharing, but the Entra Conditional Access design is out of scope.

- **B2B identity architecture.** Entra External ID / cross-tenant access settings are referenced as the

identity substrate for guests, but their full design is a separate identity product.

The determination boundary (read this before configuring)

What the policy should be — which domains are trusted, which sites are "confidential", how long a guest may retain access, what an acceptable external-exposure posture is — is a security/compliance/data-governance determination, not the implementer's. This solution supplies the **technical method** (the exact settings, cmdlets, gates, and evidence) and the **reporting** to inform that decision; it does not decide the policy. Sensitivity-label definitions in particular are **authored by the compliance owner in Microsoft Purview** — this solution applies an already-published label to a container.

Why this matters

- **"Anyone" links are unauthenticated and forwardable.** An Anyone (anonymous) link works for whoever

holds the URL, with no sign-in — great for frictionless sharing, dangerous for sensitive content. If the tenant default link type is "Anyone" and links never expire, exposure accumulates silently.

• **Guests accumulate and go stale.** External users invited for a project remain long after it ends.

Without expiration and periodic **access reviews**, the guest population — and what it can reach — only grows.

• **Sharing to any domain is sharing to competitors.** Without an **allow-list** (share only to named

partner domains) or **block-list** (never share to these), a user can invite anyone.

• **You cannot govern what you cannot see.** Most tenants have no routine view of which sites carry

Anyone-links, which have EEEU, or who the external users are. **External-exposure reporting** turns that blind spot into a monitored, auditable posture.

How it works

1. **Assess the current posture first (read-only).** Capture the tenant sharing capability, OneDrive

sharing capability, default link type/permission, expiration settings, domain mode, guest-expiration settings, per-site sharing capability for the sites in scope, and the external-user population. This is the `External Exposure – SPO – Discovery` baseline and the evidence for the policy decision.

1. **Set the tenant sharing baseline.** With `Set-SPOTenant`, set the tenant `SharingCapability` to

the approved level, set `DefaultSharingLinkType` to *Specific people* (`Direct`) and `DefaultLinkPermission` to *View*, require **Anyone-link expiration** (`RequireAnonymousLinksExpireInDays`), require **guest-access expiration** (`ExternalUserExpirationRequired` + `ExternalUserExpireInDays`), and set the **domain restriction mode** and its allow/block list. This is `Tenant Sharing Baseline – SPO – Prod`.

1. **Align OneDrive.** Set `OneDriveSharingCapability` no looser than the SharePoint tenant setting

(it cannot exceed it) so personal OneDrive sharing matches policy.

1. **Tighten sites that need it.** With `Set-SPOSite`, set a more restrictive **per-site

`SharingCapability`**, per-site link defaults, per-site domain lists, and per-site Anyone-link expiration overrides (`OverrideTenantAnonymousLinkExpirationPolicy`) on the sites that hold sensitive content — a site can be** tighter** than the tenant, never looser.

1. **Apply sensitivity-label container controls.** For Group-connected sites, apply the compliance-owned

sensitivity label whose **container settings** enforce external-sharing scope (and privacy / unmanaged-device access) at the container level — `Container Label – <Level> – Prod`. The label is published by the compliance owner; this solution applies it.

1. **Stand up guest access reviews.** Use **Microsoft Entra Access Reviews** (Graph / Entra portal) to

review the guest population and the membership of externally-shared groups on a recurring cadence — `Access Review – Guests – Quarterly` — so access that is no longer needed is removed.

1. **Report external exposure on a cadence.** Enumerate sharing links and external principals across the

sites in scope, plus the SharePoint **Data Access Governance (DAG)** reports, to produce `External Exposure – SPO – Report` — the recurring audit artifact.

Every change is **pilot-first**, on a named `Sharing Scope – Pilot – Stage1` set, with explicit pass/fail gates and a rollback, before expanding to `Sharing Scope – Broad – Stage2`.

The reference model (artifacts this solution creates)

Every artifact is named `<Purpose> – <Scope> – <Stage>` and reused verbatim across the docs, scripts, the admin centers, and reports.

Artifact	Name
Read-only external-exposure baseline export	`External Exposure – SPO – Discovery`
Tenant + OneDrive sharing baseline (Set-SPOTenant)	`Tenant Sharing Baseline – SPO – Prod`
Pilot site scope	`Sharing Scope – Pilot – Stage1`
Broad site scope	`Sharing Scope – Broad – Stage2`
Per-site tightened sharing (Set-SPOSite)	`Site Sharing – <SiteName> – Prod`
Default sharing-link type/permission	`Link Default – Specific-People-View – Prod`
Anyone-link expiration policy	`Anyone Link Expiration – 30d – Prod`
Guest-access expiration policy	`Guest Expiration – 60d – Prod`
Domain allow-list (share only to these)	`Domain Allowlist – Partners – Prod`
Domain block-list (never share to these)	`Domain Blocklist – Restricted – Prod`
Sensitivity label applied to a container	`Container Label – <Level> – Prod`
Recurring guest access review	`Access Review – Guests – Quarterly`
Recurring external-exposure report	`External Exposure – SPO – Report`

> *Replace `<SiteName>` and `<Level>` with your real site title and your published sensitivity-label name. The domain lists, expiration values (30d/60d are illustrative), and label names are the policy owner's determination — do not invent them.*

Benefits

• Sharing is **enabled but bounded** — the tenant/OneDrive/site capability matches approved policy, not the Microsoft default.

• New links default to **Specific people / View** and **Anyone-links expire**, so casual sharing stops creating unauthenticated, permanent exposure.

• External sharing is **domain-restricted** — only trusted partner domains (allow-list) or never blocked domains (block-list).

• Guests are **time-boxed and reviewed** on a cadence, so external access does not accumulate.

- External exposure is **visible and auditable** through a recurring report and the DAG reports.
- Every change is **pilot-first** with pass/fail gates and a rollback, so tenant-wide sharing — a

high-impact change — is de-risked.

Limitations (be honest with buyers)

- **Site sharing cannot exceed tenant sharing.** A per-site `SharingCapability` can only be **equal to

or more restrictive **than the tenant setting; you cannot make one site "Anyone" if the tenant is "New and existing guests". Tightening the tenant setting** retroactively caps** looser sites.

- **Tightening tenant sharing can break existing links.** Reducing `SharingCapability` (e.g. removing

Anyone) **disables** existing links of the now-disallowed type. This is why the rollout is pilot-first with a rollback and stakeholder sign-off.

- **Sharing settings are not instant tenant-wide.** `Set-SPOTenant` changes can take time to propagate

across the service; validate after a propagation window, not immediately.

- **Sensitivity-label container controls are Purview-owned and license-dependent.** Applying a label

requires the label to be **published** by the compliance owner, and container-label features depend on the plan — **verify in your tenant/plan**. This solution applies a label; it does not author one.

- **Access Reviews are an Entra ID Governance feature and are license-dependent.** Entra Access Reviews

require **Microsoft Entra ID P2 / Microsoft Entra ID Governance** licensing — **verify in your tenant/plan**. Where that licensing is absent, this solution provides a scripted review artifact as a fallback.

- **Reporting is a snapshot, and enumeration has limits.** Link/permission enumeration through Graph and

PnP reflects the moment it runs and can be throttled on very large tenants; treat the report as a recurring cadence, not a live feed. The SharePoint **DAG** reports themselves are a plan-dependent admin-center feature.

- **Commercial vs Government clouds differ.** Admin-center and tenant URLs differ on **GCC / GCC High /

DoD (`*.sharepoint.us`, `*.office365.us`, and Graph/endpoint variants); connect commands and some feature availability differ —** verify on your cloud**.

The standard deployment model

> ***Assess*** *the current sharing/exposure posture and licensing →* ***Design*** *the tenant baseline, site tiers, link defaults, domain lists, and review cadence (with the policy owner) →* ***Configure*** *them → apply to a* ***Pilot*** *scope first →* ***Validate*** *(sharing scoped to policy, links defaulted + expiring, external exposure visible, stale access reviewed) →* ***Expand*** *to the broad scope. Pattern:* ***Assess*** *→* ***Design*** *→* ***Configure*** *→* ***Pilot*** *→* ***Validate*** *→* ***Expand****, with explicit pass/fail gates and a documented rollback.*

*Tenant-wide sharing is **high-impact** — this is not optional.*

2. Requirements — SharePoint Online External Sharing & Access Governance

These are the **solution-specific** prerequisites for external sharing & access governance. They build **on top of** the shared SharePoint-category requirements in `global-requirements-sharepoint.md` (a licensed SharePoint Online / OneDrive tenant, least-privilege SharePoint admin access, the SPO Management Shell / PnP / Graph toolchain, an information-architecture + identity/group source of truth, a pilot scope + change control, and security/compliance/records stakeholders). Do not duplicate those six — verify them there first, then confirm the items below.

Each item lists **Description / Why / Verify / Implement if missing**.

2.1 SharePoint Administrator role (and Global Admin only where noted)

• **Description:** The **SharePoint Administrator** Entra role, which grants access to the SharePoint admin center and the `Set-SPOTenant` / `Set-SPOSite` cmdlets. Tenant-wide sharing changes are made here; a small number of adjacent tasks (publishing a sensitivity label, creating an Entra Access Review) need **Compliance/Purview** or **Identity Governance** roles held by their respective owners.

• **Why required:** `Set-SPOTenant` (tenant `SharingCapability`, default link type, expiration, domain mode) requires SharePoint Administrator; you should **not** run this work as Global Administrator by default (least privilege).

• **How to verify:** Microsoft 365 admin center → **Roles**, or Entra admin center → **Roles & admins**, **confirm the operator holds** SharePoint Administrator**. Confirm `Connect-SPOService` to the `-admin` URL succeeds.

• **How to implement if missing:** Have a Global Administrator assign **SharePoint Administrator** under change control. For label publishing / access reviews, confirm the compliance and identity-governance owners hold their roles — those steps are theirs, not the SharePoint admin's.

2.2 SharePoint Online Management Shell connected to the admin endpoint

• **Description:** The **Microsoft.Online.SharePoint.PowerShell** module (SharePoint Online Management Shell), connected with `Connect-SPOService -Url https://<tenant>-admin.sharepoint.com` (Commercial), or the **Government** admin URL for your cloud (e.g. `https://<tenant>-admin.sharepoint.us` — **verify your cloud's admin host**).

• **Why required:** All tenant/site sharing settings (`Get-/Set-SPOTenant`, `Get-/Set-SPOSite`, `Get-SPOExternalUser`) run through this module against the **admin** endpoint, not a site URL.

• **How to verify:** `Get-Module -ListAvailable Microsoft.Online.SharePoint.PowerShell`, then

`Connect-SPOService -Url https://<tenant>-admin.sharepoint.com` and `Get-SPOTenant` returns settings.

- **How to implement if missing:** `Install-Module Microsoft.Online.SharePoint.PowerShell -Scope CurrentUser. On Government clouds pass -Region ITAR/the correct region and the .us` admin host.

2.3 PnP PowerShell for link + permission enumeration

- **Description: PnP.PowerShell** for enumerating sharing links and permissions at the site/file/folder level (`Get-PnPFileSharingLink`, `Get-PnPFolderSharingLink`, `Get-PnPTenantSite`), connected with `Connect-PnPOnline` using an **app registration** (interactive or certificate) with the delegated/app permissions your tenant requires.
- **Why required:** Tenant/site *settings* come from SPO cmdlets, but the **actual sharing links and external principals** (the exposure inventory that feeds `External Exposure – SPO – Report`) are read through PnP / Graph, not `Set-SPOTenant`.
- **How to verify:** `Get-Module -ListAvailable PnP.PowerShell`; `Connect-PnPOnline -Url https://<tenant>.sharepoint.com/sites/<pilot> -Interactive succeeds and Get-PnPFileSharingLink` runs against a document library.
- **How to implement if missing:** `Install-Module PnP.PowerShell -Scope CurrentUser`. Register the PnP Entra app (`Register-PnPEntraIDAppForInteractiveLogin` or your own app registration) and consent to the required Sites/Graph permissions. Modern-auth only — **no stored credentials in scripts.**

2.4 Microsoft Graph PowerShell for guests and access reviews

- **Description:** The **Microsoft.Graph** PowerShell SDK, connected with `Connect-MgGraph` using the scopes the tasks need (e.g. `Sites.Read.All`, `User.Read.All` for exposure reporting; `AccessReview.ReadWrite.All` for creating reviews — the latter held by the identity-governance owner).
- **Why required:** Guest enumeration and **Entra Access Reviews** are Graph/Entra features; external principals on sharing links resolve through Graph.
- **How to verify:** `Connect-MgGraph -Scopes "Sites.Read.All","User.Read.All"` succeeds; `Get-MgUser -Filter "userType eq 'Guest'"` returns the guest population.
- **How to implement if missing:** `Install-Module Microsoft.Graph -Scope CurrentUser`; consent to the scopes. On Government clouds pass `Connect-MgGraph -Environment USGov/USGovDoD` as appropriate.

2.5 A documented external-sharing policy (from the policy owner)

• **Description:** A written statement of the **approved** sharing posture: the tenant sharing level,

the default link type/permission, the Anyone-link expiration and guest-expiration values, the **allow-list or block-list of domains**, which site tiers are "confidential" and how tight they must be, and the guest-review cadence.

• **Why required:** Every setting this solution applies encodes a **policy decision**. The technical

method is ours; the *values* are the security/compliance owner's determination (see Overview → "The determination boundary"). Configuring without an agreed policy risks either breaking collaboration (too tight) or leaving exposure (too loose).

• **How to verify:** Confirm a signed-off policy document naming the values above and the approver.

• **How to implement if missing:** Run the **Assess** stage (Discovery report) and workshop the policy

with the security/compliance stakeholders **before** touching production sharing settings.

2.6 Sensitivity labels published (if label-driven controls are in scope)

• **Description:** If the design uses **sensitivity-label container controls**, the labels must already

be **created and published** in **Microsoft Purview** by the compliance owner, with **group & site** (container) protection settings configured (privacy, external sharing, unmanaged-device access), and container labeling **enabled** for the tenant.

• **Why required:** This solution **applies** a published label to a container (`Set-SPOSite

-SensitivityLabel <id>` / Purview) — it cannot apply a label that does not exist, and it does not author label taxonomy or file-level encryption.

• **How to verify:** In the Purview portal → **Information protection** → **Labels**, confirm the label

exists and is **published** to the right scope, with container settings on. Container labeling for SharePoint/Groups is enabled (a tenant-level enablement — **verify in your tenant/plan**, it is license-dependent).

• **How to implement if missing:** The **compliance owner** creates and publishes the label and enables

container labeling. If label-driven controls are not in scope, this requirement does not apply — use site-level `SharingCapability` instead.

2.7 Entra ID Governance licensing for Access Reviews (if reviews are in scope)

• **Description: Microsoft Entra ID P2** or **Microsoft Entra ID Governance** licensing, required to

create and run **Access Reviews** for the guest population and externally-shared groups.

• **Why required:** Recurring, attested guest access reviews (`Access Review – Guests – Quarterly`) are

an Entra ID Governance capability; the feature is **not** available on lower plans.

• **How to verify:** Confirm the licensing in the M365 admin center; in the Entra admin center →

Identity Governance → **Access reviews**, confirm you can create a review.

• **How to implement if missing:** Acquire the licensing, **or** use the scripted guest-review fallback (`SPOEXT-ExposureReport.ps1` enumerates guests + their external access for a manual attestation). The fallback is a report, not an enforced governance workflow — flag the gap to the policy owner.

2.8 A named pilot scope of sites and users

• **Description:** A concrete `Sharing Scope – Pilot – Stage1` set — a handful of representative site collections (a team site, a communication site, a "confidential" site) and, ideally, a set of pilot OneDrive users — to validate settings on before tenant-wide change.

• **Why required:** Tenant `SharingCapability` is tenant-wide and high-impact; site-level tightening and link-default/expiration behavior must be proven on a small scope first. (Note: some tenant settings are genuinely tenant-wide and cannot be piloted per-site — those are validated in a change window with a rollback, per the Implementation guide.)

• **How to verify:** Confirm the named site URLs and pilot user list, and a change window/approval for the tenant-wide portions.

• **How to implement if missing:** Select and document the pilot sites/users with the site owners, and agree the change window and rollback with change control before Stage 2 (Configure).

Global Requirements — SharePoint Online & OneDrive Solutions

These requirements apply to **every** solution in the **SharePoint** category (SharePoint Online architecture & provisioning, external sharing, OneDrive for Business, migration to SPO, permissions, search, and records/retention). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every SharePoint solution).*** *The **SharePoint admin center**, the **Microsoft 365 admin center**, the **SharePoint Online Management Shell** and **PnP PowerShell**, and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Where a capability, setting, or portal path is **plan- or version-dependent** (storage limits, sharing controls, Syntex/records features, Commercial vs Government cloud), it is **cited or flagged "verify in your tenant"** — never invented. **Third-party migration and governance tools** (e.g. ShareGate, Migration Manager, AvePoint) are integrated at the pattern level; their consoles are deferred to the vendor's docs. Automation is **PowerShell** (SPO Management Shell / PnP / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with SharePoint Online / OneDrive and licensing

• **Description:** A Microsoft 365 tenant with **SharePoint Online** and **OneDrive for Business** and the licensing the capability requires (e.g. an E-plan for advanced records/retention, Syntex where used).

• **Why required:** All site, sharing, OneDrive, and records configuration depends on the right plan.

• **How to verify:** In the M365 admin center confirm the SharePoint/OneDrive subscription and add-ons.

- **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Administrative access (least-privilege SharePoint roles)

- **Description:** Access with the least-privilege role the solution names — typically **SharePoint Administrator** (and Global Administrator only where genuinely required, e.g. tenant-wide sharing).
- **Why required:** Tenant/site settings, sharing, provisioning, and records changes require the role.
- **How to verify:** Confirm the role in the M365 admin center / Entra roles.
- **How to implement if missing:** Have a Global Admin assign the least-privilege role under change control.

3. SharePoint Online Management Shell / PnP + Graph toolchain

- **Description:** A workstation with the **SharePoint Online Management Shell** and/or **PnP PowerShell** (and Graph PowerShell where used), modern-auth / MFA-capable admin sign-in (PnP app registration where required).
- **Why required:** Configuration, automation, and the provided scripts run through SPO/PnP/Graph.
- **How to verify:** `Connect-SPOService` / `Connect-PnPOnline` succeeds; modules installed.
- **How to implement if missing:** Install the modules; register the PnP app where needed; confirm sign-in.

4. Information architecture & identity/group source of truth

- **Description:** A defined **information-architecture** intent (hub/site structure, taxonomy) and the identity/group source (Entra ID groups, M365 Groups backing team sites) that drives access.
- **Why required:** Provisioning, permissions, search, and governance key off the IA and groups.
- **How to verify:** Confirm the intended hub/site structure and which groups model is authoritative.
- **How to implement if missing:** Define the IA and group model (often the Architecture solution) first.

5. A pilot scope and change control

- **Description:** A **pilot site collection / hub / user set** to validate on before tenant-wide rollout, and a **change-control** process for production changes (sharing, permissions, retention, migration cutover are high-impact).
- **Why required:** Every solution follows an **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand** model; tenant-wide sharing/permission/retention changes are high-impact.
- **How to verify:** Confirm a named pilot scope and an approval/change window are available.
- **How to implement if missing:** Create a pilot scope and agree change control before production changes.

6. Security, compliance & records stakeholders

• **Description:** Engagement with the **security, compliance/records, and data-governance** stakeholders

whose policies the configuration must satisfy (external sharing, permissions, retention/records, sensitivity).

• **Why required:** Sharing, permission, and records settings must align to enterprise policy.

• **How to verify:** Confirm the applicable policies and named approvers.

• **How to implement if missing:** Identify the owners and capture requirements before configuring governance.

*The deployment model across every SharePoint solution is the same: **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand**, with explicit pass/fail gates and a documented rollback for production changes. Automation is delivered as **PowerShell** (SPO Management Shell / PnP / Graph) — never with hardcoded credentials or secrets in code.*

3. Implementation — SharePoint Online External Sharing & Access Governance

Follow the house model: **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand**, with explicit pass/fail gates and a documented rollback. Tenant-wide sharing is **high-impact** — do not skip the pilot/change-window discipline.

> ***Naming:*** *every artifact you create is named* `<Purpose> – <Scope> – <Stage>` *per the Overview's reference model and reused verbatim in the admin centers, scripts, testing, and reports.* ***Connections used throughout:*** *- SPO Management Shell:* `Connect-SPOService -Url https://<tenant>-admin.sharepoint.com` *(Government: your* `.us` *admin host — verify your cloud). - PnP:* `Connect-PnPOnline -Url https://<tenant>.sharepoint.com/sites/<site> -Interactive`*. - Graph:* `Connect-MgGraph -Scopes "Sites.Read.All","User.Read.All"` *(add* `AccessReview.ReadWrite.All` *for reviews;* `-Environment USGov/USGovDoD` *on Gov clouds). -* `contoso.com` */* `fabrikam.com` *are placeholder domains — substitute your real tenant and partner domains.*

Stage 0 — Assess (read-only, changes nothing)

Goal: capture the current posture as `External Exposure – SPO – Discovery` and hand it to the policy owner as the evidence for the sharing-policy decision.

1. **Connect and capture the tenant sharing posture.** In the SharePoint admin center go to

Policies → **Sharing** to read the current external-sharing slider, default link settings, and expiration; then capture the same values in PowerShell for the record:

```
Connect-SPOService -Url https://contoso-admin.sharepoint.com
Get-SPOTenant | Select-Object SharingCapability, OneDriveSharingCapability,
    DefaultSharingLinkType, DefaultLinkPermission,
    RequireAnonymousLinksExpireInDays, ExternalUserExpirationRequired, ExternalUserExpireInDays,
    SharingDomainRestrictionMode, SharingAllowedDomainList, SharingBlockedDomainList,
```

```
    PreventExternalUsersFromResharing, RequireAcceptingAccountMatchInvitedAccount
```

1. **Capture per-site sharing** for the sites in scope and the **external-user population**:

```
Get-SPOSite -Limit All -Detailed |
    Select-Object Url, SharingCapability, Title | Sort-Object Url
Get-SPOExternalUser -PageSize 50   # external users who accepted invitations
```

1. **Run the discovery script** to produce the baseline CSV in one pass:

`.\SPOEXT-Discovery.ps1 -CsvPath .\External-Exposure-Discovery.csv` (read-only). Save the output as `External Exposure – SPO – Discovery`.

1. **Review the SharePoint Data Access Governance (DAG) reports** in the admin center →

Reports → **Data access governance** (e.g. **Sharing links**, **Everyone Except External Users (EEEU)**) for oversharing signals. *(DAG report availability is plan-dependent — verify in your tenant.)*

Gate 0 (pass to proceed): you have a saved discovery baseline (tenant + OneDrive + per-site capability, link defaults, expiration, domain mode, guest population) and have reviewed the DAG signals. **Fail:** if you cannot read `Get-SPOTenant`/`Get-SPOExternalUser`, fix Requirements 2.1–2.2 first.

Stage 1 — Design (with the policy owner; no changes yet)

Goal: agree the values that the settings will encode. Record them in the policy document (Requirement 2.5). Decide, with the security/compliance owner:

- **Tenant** `SharingCapability` — the approved level. The four values are:
- `Disabled` — no external sharing.
- `ExistingExternalUserSharingOnly` — only guests already in the directory.
- `ExternalUserSharingOnly` — **New and existing guests** (sign-in / verification-code required).
- `ExternalUserAndGuestSharing` — **Anyone** links allowed (unauthenticated) **plus** guests.

A common governed target is `ExternalUserSharingOnly` (new + existing guests, no Anyone links).

- `OneDriveSharingCapability` — equal to or tighter than the tenant value.
- `DefaultSharingLinkType` = `Direct` (**Specific people**) and `DefaultLinkPermission` = `View`.
- **Anyone-link expiration** (`RequireAnonymousLinksExpireInDays`, e.g. `30`) — only relevant if Anyone

is permitted; name it `Anyone Link Expiration – 30d – Prod`.

- **Guest-access expiration** (`ExternalUserExpireInDays`, e.g. `60`) — `Guest Expiration – 60d – Prod`.
- **Domain restriction** — `SharingDomainRestrictionMode` = `AllowList` with a partner allow-list

(`Domain Allowlist – Partners – Prod`) **or** `BlockList` (`Domain Blocklist – Restricted – Prod`).

- **Confidential site tiers** — which sites get a tighter per-site `SharingCapability` and/or a

sensitivity-label container control, named `Site Sharing – <SiteName> – Prod` / `Container Label – <Level> – Prod`.

• **Guest-review cadence** — quarterly is typical: `Access Review – Guests – Quarterly`.

Gate 1: a signed-off policy document with every value above and the approver named, plus the `Sharing Scope – Pilot – Stage1` site/user list and a change window for the tenant-wide portions.

Stage 2 — Configure & Pilot

> ***Sequencing note.*** *Tenant* `SharingCapability`*, default link type, expiration, and domain mode are* ***tenant-wide*** *— they cannot be scoped to a pilot site. Therefore:* ***first*** *prove the *tighter site-level* and *link/expiration behavior* on the pilot sites (which you can scope),* ***then*** *apply the tenant-wide baseline in the agreed change window with the rollback ready. Do all writes with the config script's dry-run first.*

2a. Pilot the per-site tightening (scoped, reversible)

1. **Record each pilot site's current** `SharingCapability` (for rollback) from Stage 0.
2. **Tighten a confidential pilot site** below the tenant default and set its link defaults:

```
$site = 'https://contoso.sharepoint.com/sites/Confidential-Pilot'
Set-SPOSite -Identity $site -SharingCapability ExistingExternalUserSharingOnly
Set-SPOSite -Identity $site -DefaultSharingLinkType Direct -DefaultLinkPermission View
# Per-site Anyone-link expiration override (only if Anyone is allowed at that site):
Set-SPOSite -Identity $site -OverrideTenantAnonymousLinkExpirationPolicy $true `
    -AnonymousLinkExpirationInDays 30
```

Name this `Site Sharing – Confidential-Pilot – Prod`.

1. **Apply a per-site domain restriction** on the pilot site if the design calls for it:

```
Set-SPOSite -Identity $site -SharingDomainRestrictionMode AllowList `
    -SharingAllowedDomainList "fabrikam.com contoso-partner.com"
```

1. **Apply the sensitivity-label container control** (if in scope; label must be **published** —

Requirement 2.6). Get the label GUID from the compliance owner / `Get-Label` (Purview PowerShell) and apply it:

```
Set-SPOSite -Identity $site -SensitivityLabel "<published-label-GUID>"
```

Name this `Container Label – Confidential – Prod`. *(Container-label enforcement of external sharing is defined in the label by the compliance owner — you are applying it, not authoring it.)*

1. **Use the config script for the batch/dry-run path** so every write is previewed first:

```
.\SPOEXT-Set-Sharing.ps1 -SiteScope (Get-Content .\pilot-sites.txt) `
    -SiteSharingCapability ExistingExternalUserSharingOnly -WhatIf   # dry run
.\SPOEXT-Set-Sharing.ps1 -SiteScope (Get-Content .\pilot-sites.txt) `
    -SiteSharingCapability ExistingExternalUserSharingOnly -Commit    # apply
```

Gate 2a: on the pilot site, a **new share** offers *Specific people / View* by default, an **Anyone link** (if permitted) shows an expiration, an attempt to share to a **non-allowed domain is blocked**, and the site's `SharingCapability` reads the tightened value. Rollback: `Set-SPOSite -Identity $site -SharingCapability <original>` (and restore the original link defaults / domain mode).

2b. Apply the tenant baseline (change window)

Preview, then apply, `Tenant Sharing Baseline – SPO – Prod`. Do the dry run first:

```
.\SPOEXT-Set-Sharing.ps1 -TenantBaseline -SharingCapability ExternalUserSharingOnly `
    -DefaultLinkType Direct -DefaultLinkPermission View `
    -AnonymousLinkExpireDays 30 -GuestExpireDays 60 `
```

```
    -DomainMode AllowList -DomainList "fabrikam.com contoso-partner.com" -WhatIf
```

The equivalent direct cmdlets (what the script runs on `-Commit`):

```
Set-SPOTenant -SharingCapability ExternalUserSharingOnly
Set-SPOTenant -OneDriveSharingCapability ExistingExternalUserSharingOnly   # <= tenant
Set-SPOTenant -DefaultSharingLinkType Direct -DefaultLinkPermission View
Set-SPOTenant -RequireAnonymousLinksExpireInDays 30        # if Anyone permitted
Set-SPOTenant -ExternalUserExpirationRequired $true -ExternalUserExpireInDays 60
Set-SPOTenant -SharingDomainRestrictionMode AllowList `
    -SharingAllowedDomainList "fabrikam.com contoso-partner.com"
Set-SPOTenant -PreventExternalUsersFromResharing $true `
    -RequireAcceptingAccountMatchInvitedAccount $true
```

> ***Order matters:*** *if you are* ***tightening*** *the tenant (e.g. removing Anyone), announce it — existing Anyone links of the now-disallowed type are* ***disabled****. Apply in the change window with the rollback (`Set-SPOTenant -SharingCapability <original>` plus the original link/expiration/domain values, all captured in Stage 0) staged and ready.*

Gate 2b: `Get-SPOTenant` reflects every baseline value; a tenant-wide new-share defaults to *Specific people / View*; sharing to a non-allowed domain is blocked tenant-wide; a newly invited guest receives an expiration. **Fail** → **rollback** to the Stage 0 values and reconvene with the policy owner.

2c. Stand up guest access reviews

1. **In the Entra admin center** → **Identity Governance** → **Access reviews**, create a recurring review

`Access Review – Guests – Quarterly` scoped to **Guest users** (and/or the membership of externally-shared M365 groups), with reviewers = group owners or the sponsoring managers, a **recurrence** of quarterly, and **auto-apply** of results (remove access if not approved / not responded per policy). *(Access Reviews require Entra ID P2 / ID Governance — Requirement 2.7.)*

1. **If Access Reviews are not licensed**, run the fallback: `.\SPOEXT-ExposureReport.ps1

-IncludeGuests -CsvPath .\Guest-Review.csv` and route the CSV to owners for manual attestation. Flag the licensing gap to the policy owner.

Gate 2c: the recurring review exists (or the fallback CSV is produced and routed) and a first cycle has an owner and a due date.

Stage 3 — Validate

Run the validation script against the pilot and the tenant baseline:

```
.\SPOEXT-Validation.ps1 -SiteScope (Get-Content .\pilot-sites.txt) `
    -ExpectSharingCapability ExternalUserSharingOnly `
    -ExpectDefaultLinkType Direct -ExpectDefaultLinkPermission View `
    -ExpectDomainMode AllowList
```

It returns PASS/FAIL per check. Then run `.\SPOEXT-ExposureReport.ps1 -SiteScope (Get-Content .\pilot-sites.txt) -CsvPath .\External-Exposure-Report.csv` to produce `External Exposure – SPO – Report` and confirm the exposure inventory matches expectations (no unexpected Anyone-links, external principals only on trusted domains). Full procedures are in **05-testing.md**.

Gate 3: every validation check PASSes and the exposure report shows no out-of-policy sharing. Any FAIL is remediated (or rolled back) before Expand.

Stage 4 — Expand

1. **Widen the site-level tightening** from `Sharing Scope – Pilot – Stage1` to `Sharing Scope – Broad

– Stage2` in tranches, running the config script in **dry-run then commit** per tranche and re-validating after each:

```
.\SPOEXT-Set-Sharing.ps1 -SiteScope (Get-Content .\wave2-sites.txt) `
    -SiteSharingCapability ExistingExternalUserSharingOnly -WhatIf
```

1. **Schedule the recurring exposure report** (`External Exposure – SPO – Report`) and confirm the

`Access Review – Guests – Quarterly` recurrence is active.

1. **Hand over** the policy document, the discovery baseline, the validation output, and the report

cadence to operations. Keep the Stage 0 values retained as the standing rollback reference.

Gate 4 (done): the tenant baseline and all in-scope site tiers match policy, guest reviews recur, the exposure report runs on a cadence, and the rollback values are archived.

Rollback summary (keep ready at every stage)

Change	Rollback
Tenant `SharingCapability` tightened	`Set-SPOTenant -SharingCapability <Stage-0 value>` (existing links of a re-allowed type do **not** auto-restore)
Default link type/permission	`Set-SPOTenant -DefaultSharingLinkType <orig> -DefaultLinkPermission <orig>`
Anyone/guest expiration	Restore original `RequireAnonymousLinksExpireInDays` / `ExternalUserExpireInDays` (or `ExternalUserExpirationRequired $false`)
Domain mode/list	`Set-SPOTenant -SharingDomainRestrictionMode None` (or restore original mode + lists)
Per-site tightening	`Set-SPOSite -Identity <url> -SharingCapability <orig>` + original link/domain values
Sensitivity label applied	Re-apply the prior label or clear per the compliance owner's guidance

5. Testing & Validation — SharePoint Online External Sharing & Access Governance

Each test states **how to run it** and the **expected pass/fail**. Run them at the pilot gate and after every expansion tranche. Automate the repeatable ones with `SPOEXT-Validation.ps1` and `SPOEXT-ExposureReport.ps1`. Substitute your real tenant, site URLs, and domains for the `contoso.com` / `fabrikam.com` placeholders.

T1 — Tenant sharing baseline is in effect

- **Run:**

```
Get-SPOTenant | Select-Object SharingCapability, OneDriveSharingCapability,
    DefaultSharingLinkType, DefaultLinkPermission, ExternalUserExpirationRequired,
    ExternalUserExpireInDays, RequireAnonymousLinksExpireInDays, SharingDomainRestrictionMode
```

- **Pass:** every value matches `Tenant Sharing Baseline – SPO – Prod` (e.g. `SharingCapability =

ExternalUserSharingOnly, DefaultSharingLinkType = Direct, DefaultLinkPermission = View, ExternalUserExpirationRequired = True`).

- **Fail:** any value differs → re-apply that setting (Implementation 2b) or investigate propagation

delay (re-check after the propagation window).

T2 — OneDrive sharing is no looser than the tenant

- **Run:** compare `OneDriveSharingCapability` to `SharingCapability` (from T1).
- **Pass:** `OneDriveSharingCapability` is **equal to or tighter** than the tenant `SharingCapability`.
- **Fail:** OneDrive is looser → `Set-SPOTenant -OneDriveSharingCapability <= tenant`.

T3 — Default sharing link is Specific people / View

- **Run:** as a normal user in a pilot site, click **Share** on a document and read the default link

scope and permission (do not send). Confirm in PowerShell via `DefaultSharingLinkType` / `DefaultLinkPermission`.

- **Pass:** the share dialog defaults to **Specific people** and **Can view** (not "Anyone", not "Can

edit").

- **Fail:** default is "Anyone" or "Edit" → re-apply `Set-SPOTenant`/`Set-SPOSite` link defaults.

T4 — Anyone-link expiration is enforced (only if Anyone is permitted)

- **Run:** where `SharingCapability` allows Anyone, create an **Anyone** link on a test file and read

the expiration; check `RequireAnonymousLinksExpireInDays`.

- **Pass:** the Anyone link carries an expiration ≤ the policy value (e.g. 30 days) and cannot be set

beyond it. If the tenant does **not** permit Anyone links, this test is **N/A** (T5 should show Anyone is disallowed).

• **Fail:** an Anyone link is created with no/over-limit expiration → re-apply the expiration setting.

T5 — External sharing level blocks disallowed link types

• **Run:** on a site set to `ExternalUserSharingOnly`, attempt to create an **Anyone** link; on a site set to `ExistingExternalUserSharingOnly`, attempt to invite a **brand-new** external user.

• **Pass:** the disallowed action is unavailable/blocked (no Anyone option on the first; the second cannot invite a not-yet-directory guest).

• **Fail:** the disallowed action succeeds → the site/tenant `SharingCapability` is not what you expect; re-check T1 and the site value.

T6 — Guest-access expiration applies to new guests

• **Run:** invite a test external user to a pilot site; in the SharePoint admin center → **More features → External users**, or via Graph, confirm an expiration is set.

• **Pass:** the new guest shows an expiration date consistent with `Guest Expiration – 60d – Prod`.

• **Fail:** no expiration → confirm `ExternalUserExpirationRequired = True` and `ExternalUserExpireInDays`.

T7 — Domain allow/block restriction is enforced

• **Run:** attempt to share to an **allowed** partner domain (e.g. `fabrikam.com`) and to a **non-allowed** domain (e.g. `random-external.com`).

• **Pass:** the allowed domain succeeds; the non-allowed domain is **blocked** with a clear message. (`SharingDomainRestrictionMode = AllowList` + `SharingAllowedDomainList` contains the allowed domain.)

• **Fail:** a non-allowed domain succeeds, or an allowed domain is blocked → correct the mode / list (tenant or per-site). Remember per-site lists apply on top of the tenant.

T8 — Sensitivity-label container control is applied (if in scope)

• **Run:** `Get-SPOSite -Identity <confidential-site> | Select-Object SensitivityLabel`; open the site and confirm the label badge and that its external-sharing container setting is in effect.

• **Pass:** the site shows `Container Label – <Level> – Prod` and its external-sharing behavior matches the label's published container setting.

• **Fail:** no label / wrong behavior → confirm the label is **published** (Requirement 2.6) and re-apply `Set-SPOSite -SensitivityLabel <id>`.

T9 — External-exposure report is complete and accurate

• **Run:** `.\SPOEXT-ExposureReport.ps1 -SiteScope (Get-Content .\pilot-sites.txt) -CsvPath .\External-Exposure-Report.csv` and open the CSV; cross-check a few rows against a site's actual sharing.

• **Pass:** the report (`External Exposure – SPO – Report`) lists each pilot site's sharing links (type, expiration, principal), external users, and flags Anyone-links / no-expiration / out-of-policy domains; spot-checked rows match reality.

• **Fail:** missing sites or principals → check PnP/Graph permissions (Requirements 2.3–2.4) and throttling on large sites (re-run scoped).

T10 — Guest access review runs and removes stale access

• **Run:** confirm `Access Review – Guests – Quarterly` exists and its first cycle has reviewers and a due date; simulate a "deny" on a test guest and confirm auto-apply removes access (or, for the fallback, confirm the CSV was routed and actioned).

• **Pass:** the review recurs, reviewers are assigned, and a denied guest loses access on apply.

• **Fail:** no recurrence / no removal → check the review configuration and Entra ID Governance licensing (Requirement 2.7); use the scripted fallback if unlicensed.

T11 — Rollback works

• **Run (in a change window):** loosen one pilot site back to its Stage-0 `SharingCapability`, confirm, then re-tighten.

• **Pass:** both directions apply cleanly and `Get-SPOSite` reflects each state. (Note: existing links disabled by a tightening do **not** auto-restore on loosening — that is expected, not a test failure.)

• **Fail:** rollback does not apply → resolve before Expand; do not widen scope without a proven rollback.

Validation gate summary (all must pass before Expand)

1. Tenant + OneDrive sharing scoped to policy (T1, T2).
2. Links default to Specific people / View and Anyone-links expire (T3, T4).
3. Disallowed link/guest actions blocked (T5); guests time-boxed (T6).
4. Domain allow/block enforced (T7); label container control applied where in scope (T8).
5. External exposure visible and accurate (T9); guest reviews recur and remove stale access (T10).
6. Rollback proven (T11).

6. Troubleshooting — SharePoint Online External Sharing & Access Governance

Common failure modes and their resolutions. Symptoms are grouped by where they show up. Substitute your real tenant/site/domain for the `contoso.com` / `fabrikam.com` placeholders.

Connection & tooling

`Connect-SPOService` *fails or* `Get-SPOTenant` *errors "not connected"*

- **Cause:** connected to a **site** URL instead of the **admin** endpoint, or wrong cloud host.
- **Fix:** connect to the admin URL: `Connect-SPOService -Url https://contoso-admin.sharepoint.com`

(Commercial) or your **Government** admin host (e.g. `https://contoso-admin.sharepoint.us` — **verify your cloud**). Confirm the operator holds **SharePoint Administrator** (Requirement 2.1).

PnP `Connect-PnPOnline` *fails with an app / consent error*

- **Cause:** no PnP Entra app registration or missing consent for the required permissions.
- **Fix:** register the app (`Register-PnPEntraIDAppForInteractiveLogin`) or use your own app

registration and grant admin consent to the Sites/Graph permissions, then `Connect-PnPOnline -Url <site> -Interactive` (Requirement 2.3). PnP 2.x requires PowerShell 7.

`Get-MgUser` */ access-review cmdlets fail with "insufficient privileges"*

- **Cause:** `Connect-MgGraph` was called without the needed scopes, or the operator lacks the role.
- **Fix:** reconnect with the scopes (`Sites.Read.All`, `User.Read.All`, and

`AccessReview.ReadWrite.All` for reviews). Access-review creation is the **identity-governance owner's** task, not the SharePoint admin's (Requirements 2.4, 2.7).

Settings not taking effect

A `Set-SPOTenant` *change doesn't appear immediately*

- **Cause:** tenant sharing changes **propagate** across the service; they are not always instant.
- **Fix:** wait the propagation window and re-check with `Get-SPOTenant` / `SPOEXT-Validation.ps1`. Do

not re-apply repeatedly in a tight loop — that masks the real state.

`Set-SPOSite -SharingCapability` *fails: cannot set the site looser than the tenant*

- **Cause:** a **site can only be equal to or tighter than the tenant** `SharingCapability`; you tried

to make a site more open than the tenant allows.

- **Fix:** either loosen the **tenant** (a policy decision — do not do this to accommodate one site) or

keep the site at/below the tenant level. `SPOEXT-Set-Sharing.ps1` reports the tenant level in its failure message. This is by design, not a bug.

Default link is still "Anyone" / "Edit" after configuring

- **Cause:** the **site-level** default overrides the tenant, or the change hasn't propagated, or you

read the site UI cached.

- **Fix:** set the default at the level you intend (`Set-SPOTenant -DefaultSharingLinkType Direct

-DefaultLinkPermission View, and/or Set-SPOSite ...` per site), wait for propagation, and re-test with a fresh Share dialog (Testing T3).

Sharing behavior surprises

Existing links stopped working after tightening the tenant

- **Cause:** reducing `SharingCapability` (e.g. removing Anyone) **disables existing links** of the

now-disallowed type — this is expected behavior, not a fault.

- **Fix:** this is why the rollout is **pilot-first with a change window and announcement**. If it was

unplanned, roll back the tenant `SharingCapability` to the Stage-0 value; note that **re-allowing a type does not automatically re-enable** links that were disabled — affected users must re-share.

Sharing to a non-allowed domain still succeeds (allow-list not enforced)

- **Cause:** `SharingDomainRestrictionMode` is `None`, the domain list is empty/misformatted, or a

per-site list is overriding the tenant.

- **Fix:** confirm `Get-SPOTenant | Select SharingDomainRestrictionMode, SharingAllowedDomainList`; the

list is **space-separated** (`"fabrikam.com contoso-partner.com"`). Check the site too (`Get-SPOSite -Identity <url> | Select SharingDomainRestrictionMode`). Re-apply and re-test (T7).

An allowed partner cannot be invited (allow-list too tight)

- **Cause:** the partner's domain isn't in `SharingAllowedDomainList`, or they accept with a different

domain than invited while `RequireAcceptingAccountMatchInvitedAccount` is on.

- **Fix:** add the domain to the allow-list under change control, and confirm the guest accepts with the

invited address. This is a **policy** change — route it to the policy owner, don't quietly widen it.

New guests have no expiration

- **Cause:** `ExternalUserExpirationRequired` is `$false` or `ExternalUserExpireInDays` unset; note the

expiration applies to **newly invited** guests, not retroactively to existing ones.

- **Fix:** `Set-SPOTenant -ExternalUserExpirationRequired $true -ExternalUserExpireInDays 60`; existing

guests are handled by the **access review**, not by this setting (Testing T6, T10).

Sensitivity labels

`Set-SPOSite -SensitivityLabel` *fails or the label doesn't appear*

• **Cause:** the label is **not published** to the operator/site scope, container labeling isn't enabled for the tenant, or the licensing doesn't include container-label features.

• **Fix:** confirm with the **compliance owner** that the label is **published** with container settings and that container labeling is enabled (Requirement 2.6). Container-label capability is **license-dependent — verify in your tenant/plan.** This solution applies a label; it does not author or publish one.

The site's external-sharing behavior doesn't match the label

• **Cause:** the label's **container** external-sharing setting differs from what you assumed, or a per-site `SharingCapability` and the label disagree.

• **Fix:** the **label's** container setting is authored by the compliance owner — confirm its intended behavior with them; align the per-site setting rather than overriding the label ad hoc.

Reporting & reviews

`SPOEXT-ExposureReport.ps1` *misses sites or throttles on large sites*

• **Cause:** Graph/PnP **throttling** on very large libraries, or the `-MaxItemsPerLibrary` cap trimmed results, or PnP permissions are insufficient.

• **Fix:** run the report **scoped** to fewer sites, raise/lower `-MaxItemsPerLibrary` deliberately, and confirm PnP permissions (Requirement 2.3). Treat the report as a **cadence**, not a live feed; the admin-center **Data Access Governance** reports complement it for tenant-scale signals.

Access Reviews aren't available to create

• **Cause:** the tenant lacks **Entra ID P2 / Microsoft Entra ID Governance** licensing (Requirement 2.7).

• **Fix:** acquire the licensing, or use the **scripted fallback**: `SPOEXT-ExposureReport.ps1 -IncludeGuests` produces a guest CSV for manual attestation. Flag the licensing gap to the policy owner — the fallback is a report, not an enforced governance workflow.

Government cloud

Cmdlets connect but hit the wrong tenant/endpoint on GCC High / DoD

• **Cause:** Commercial hosts/endpoints were used on a **Government** cloud.

• **Fix:** use the `.us` admin host for `Connect-SPOService`, the correct `-Region`/environment for

the SPO shell, and `Connect-MgGraph -Environment USGov/USGovDoD` for Graph. Some features differ or lag on Government clouds — **verify capability on your cloud** rather than assuming Commercial behavior.

7. Best Practices — SharePoint Online External Sharing & Access Governance

Durable practices for keeping external sharing enabled, controlled, and auditable over time.

Policy first, settings second

- **Never configure sharing without an approved policy.** Each setting encodes a security/compliance decision. Run the Discovery baseline, workshop the values with the policy owner, get sign-off, then configure. The implementer supplies the method and the evidence — not the determination.
- **Right-size the tenant level.** Default to the **least-open level that still lets the business work** — commonly **New and existing guests** (`ExternalUserSharingOnly`, no Anyone links). Reserve **Anyone** (`ExternalUserAndGuestSharing`) for tenants that genuinely need unauthenticated links, and then only with **expiration** and preferably **view-only** Anyone links.

Safe defaults beat after-the-fact cleanup

- **Default the link to Specific people / View.** `DefaultSharingLinkType = Direct` and `DefaultLinkPermission = View` stop the most common oversharing at the source — users can still choose broader when they mean to, but the safe choice is the default.
- **Expire everything external.** Require Anyone-link expiration (where Anyone is allowed) **and** guest-access expiration. Time-boxing is the cheapest control against accumulation.
- **Prevent guest re-sharing** (`PreventExternalUsersFromResharing $true`) and **require the accepting account to match the invited account** (`RequireAcceptingAccountMatchInvitedAccount $true`) so an invitation can't be forwarded to an unintended recipient.

Tighten by tier, not tenant-wide only

- **Make sensitive sites tighter than the tenant.** A per-site `SharingCapability` can only be equal to or tighter than the tenant — use that to lock down confidential sites while leaving general collaboration open. Keep the tenant at the collaboration level the majority need, and step **down** per site.
- **Prefer sensitivity-label container controls for consistency.** Where the compliance owner has published labels with container settings, applying a label carries the sharing/privacy/device posture as a unit and travels with the container — more durable than ad-hoc per-site settings.

Domains: allow-list when you can

- **Allow-list beats block-list** for high-assurance environments — you enumerate the domains you *trust* rather than chasing the infinite set you don't. Use a block-list only when open collaboration is the norm and you're excluding specific bad actors/competitors.
- **Keep the domain list under change control.** Adding a partner domain is a policy change; review the list on the same cadence as the access reviews.

Guests are a lifecycle, not a one-time invite

- **Review guests on a recurring cadence** (`Access Review – Guests – Quarterly`) with **auto-apply** so unreviewed/denied access is actually removed, not just flagged. Assign group owners as reviewers — they know who should still have access.
- **Expire, then clean up.** Guest expiration plus reviews together keep the external population from growing without bound. Periodically remove fully stale guests from the directory.

Make exposure visible on a cadence

- **Run the external-exposure report routinely**, not just at go-live. Sharing drifts as people work; the report (`External Exposure – SPO – Report`) plus the admin-center **Data Access Governance** reports (Sharing links, EEEU) turn drift into a monitored signal.
- **Watch for EEEU on externally-shared sites.** "Everyone Except External Users" combined with a broad sharing capability is a classic oversharing pattern — the DAG EEEU report surfaces it; remediate via the internal-permissions product.

Operate safely

- **Pilot every change and keep the rollback staged.** Tenant sharing is high-impact and tightening can disable existing links — always in a change window, always with the Stage-0 values retained.
- **Automate read-only, gate the writes.** Use the Discovery/Validation/Report scripts freely (they only read); run the config script **dry-run first**, then `-Commit`. **Never store credentials in scripts** — modern-auth `Connect-*` only.
- **Mind Commercial vs Government clouds.** Admin URLs, Graph endpoints, and some feature availability differ on GCC / GCC High / DoD — connect with the right host/environment and **verify capability on your cloud** rather than assuming Commercial behavior.
- **Document the boundary.** Keep this solution in its lane (external sharing & access); route internal permissions, retention/records/DLP, Conditional Access, and label authoring to their owning products so nothing falls between the cracks.

8. Deliverables Summary — SharePoint Online External Sharing & Access Governance

Documentation

Document	What it gives you
01 — Solution Overview	The sharing model (tenant vs OneDrive vs site), link types/defaults/expiration, allow/block domains, sensitivity-label container controls, guests/reviews, exposure reporting; the reference model of named artifacts; benefits, limitations, and the deployment model.
02 — Requirements	Solution-specific prerequisites (SharePoint Admin role, SPO Management Shell / PnP / Graph, a signed-off sharing policy, published sensitivity labels, Entra ID Governance licensing for reviews, a named pilot scope) — each with Verify / Implement, building on the SharePoint global requirements.
03 — Implementation	Exact ordered steps: Assess → Design → Configure/Pilot (per-site tightening, then tenant baseline in a change window, then guest reviews) → Validate → Expand, every artifact named, with pass/fail gates and a rollback table.
05 — Testing	11 validation tests (T1–T11), each with how-to-run and expected PASS/FAIL, plus the go/no-go gate summary.
06 — Troubleshooting	Common failure modes (settings not taking, site can't exceed tenant, broken links after tightening, domain block not working, guest expiration missing, PnP enumeration throttled, Gov-cloud endpoints, label not applying) and their resolutions.
07 — Best Practices	Durable practices: policy first, safe link defaults, expire-everything, tighten by tier, allow-list domains, guest lifecycle reviews, cadenced exposure reporting, safe operations.
Executive Summary	One-page outcome/approach/why-low-risk for sponsors.

PowerShell scripts (5)

All are **safe by default** — read-only or `-WhatIf`/dry-run unless you pass `-Commit`. None store credentials; all use modern-auth `Connect-*`. Connect to the SPO **admin** endpoint (and PnP per site / Graph) before running.

#	Script	Archetype	What it does
1	**SPOEXT-Discovery.ps1**	Discovery (read-only)	Captures the `External Exposure – SPO – Discovery` baseline: tenant + OneDrive sharing capability, default link type/permission, Anyone-link + guest expiration, domain mode/lists, per-site `SharingCapability`, and external-user count.
2	**SPOEXT-Set-Sharing.ps1**	Configuration/Remediation (`-WhatIf`/`-Commit`)	Applies `Tenant Sharing Baseline – SPO – Prod` (via `Set-SPOTenant`) and/or tightens sites in scope (`Set-SPOSite -SharingCapability`). Dry-run first; refuses to make a site looser than the tenant.
3	**SPOEXT-Validation.ps1**	Validation (read-only)	Compares live tenant + per-site settings against the expected policy values and prints PASS/FAIL per check (exit 1 on any fail).
4	**SPOEXT-ExposureReport.ps1**	Reporting (read-only)	Enumerates sharing links across the sites in scope via PnP (flags Anyone-links, no-expiration links, external principals) and optionally lists external users — the `External Exposure – SPO – Report` and the guest-review fallback.
5	**SPOEXT-Scope.ps1**	Scope/health helper (read-only)	Verifies modules, the SPO admin connection, Commercial-vs-Government cloud, that OneDrive is not looser than the tenant, and that every pilot-site URL resolves.

The named artifacts you end up with

External Exposure – SPO – Discovery · Tenant Sharing Baseline – SPO – Prod · Sharing Scope – Pilot – Stage1 / Sharing Scope – Broad – Stage2 · Site Sharing – <SiteName> – Prod · Link Default – Specific-People-View – Prod · Anyone Link Expiration – 30d – Prod · Guest Expiration – 60d – Prod · Domain Allowlist – Partners – Prod / Domain Blocklist – Restricted – Prod · Container Label – <Level> – Prod · Access Review – Guests – Quarterly · External Exposure – SPO – Report.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

SPOEXT-Discovery.ps1

SPOEXT-ExposureReport.ps1

SPOEXT-Scope.ps1

SPOEXT-Set-Sharing.ps1

SPOEXT-Validation.ps1